

GDPR Compliance Audit Report

Automated security and privacy compliance scan

www.boneandpayne.co.uk



CRITICAL RISK

Overall Compliance Score

REPORT GENERATED

31 May 2026

TOTAL ISSUES FOUND

13

EXECUTIVE SUMMARY



CRITICAL RISK

This report presents the results of an automated security and GDPR compliance scan of **www.boneandpayne.co.uk**, conducted on Sunday, 31 May 2026 at 13:46. Seven independent checks were performed covering HTTPS security, HTTP security headers, email authentication, open port exposure, subdomain enumeration, technology disclosure, and GDPR compliance requirements. Results reflect the publicly observable state of the website at the time of scan.

7	1	2	3	1
CHECKS RUN	PASSED	WARNINGS	FAILED	ERRORS

KEY FINDINGS

Issues are classified as Critical (failed checks requiring immediate action) or Advisory (warnings to address within 30 days).

🚫 CRITICAL ISSUES — Address Immediately (within 7 days)

HTTP Security Headers

🚫 CRITICAL FAIL

WHAT FAILED

- Missing header: Content-Security-Policy (critical)
- Missing header: Strict-Transport-Security (HSTS) (critical)
- Missing header: X-Frame-Options
- Missing header: X-Content-Type-Options
- Missing header: Referrer-Policy

BUSINESS IMPACT

No browser security protections — customer data and your reputation are at risk.

REAL-WORLD EXAMPLE — E-commerce site, ~50,000 registered customers, 2022

What happened: Missing CSP and HSTS. Attacker injected a payment skimmer script into checkout pages.

Result: 400 customers' credit card details stolen. Mandatory ICO breach report filed.

Cost: £15,000 remediation + £8,000 legal fees + ongoing ICO investigation

🕒 **Timeline: Fix within 7 days**

DNS Records — Email Authentication

🚫 CRITICAL FAIL

WHAT FAILED

- No SPF record found
- No DKIM record found (checked common selectors)
- No DMARC record found

BUSINESS IMPACT

Anyone can send emails pretending to be your business — this is an active fraud risk.

REAL-WORLD EXAMPLE — Accounting firm, 5 staff, 2023

What happened: No SPF, DKIM, or DMARC. Criminals spoofed the domain to send fake invoices to 12 clients.

Result: Clients paid fraudulent invoices totalling £50,000. Several clients pursued the firm legally.

Cost: £8,000 in legal settlements + significant reputation damage

🕒 **Timeline: Fix within 7 days**

GDPR Compliance

🚫 CRITICAL FAIL

WHAT FAILED

- No cookie consent mechanism detected
- Tracking without consent banner: Google Analytics
- No data subject rights information detected

BUSINESS IMPACT

You are actively breaking UK/EU GDPR law — immediate action required.

REAL-WORLD EXAMPLE — Online retailer, 8,000 registered customers, 2024

What happened: No privacy policy, no consent banner, multiple tracking pixels on every page.

Result: ICO formal investigation. Multiple simultaneous violations. Enforcement notice issued.

Cost: £18,000 ICO fine + £5,000 legal fees + mandatory compliance audit

🕒 **Timeline: Fix within 7 days**

⚠️ ADVISORY ISSUES — Plan to Address (within 30 days)

SSL / TLS Certificate Analysis

⚠️ ADVISORY WARNING

WHAT WAS FOUND

- Certificate expires in 29 days

Your certificate is approaching expiry — visitors will soon see security warnings.

REAL-WORLD EXAMPLE — SaaS platform, 100 active users, 2023

What happened: SSL certificate expired over a weekend. Auto-renewal had silently failed months earlier.

Cost: £3,000 in lost revenue + emergency developer call-out

📅 **Timeline: Plan to address within 30 days**

Technology Detection

⚠️ ADVISORY WARNING

WHAT WAS FOUND

- WordPress detected — ensure plugins are up to date

Technology disclosures give attackers a detailed roadmap of your system.

REAL-WORLD EXAMPLE — Restaurant chain, 3 locations, 2024

What happened: PHP and server version disclosed in response headers. Known CVE targeted within 24 hours.

Cost: £3,500 remediation + 6 hours downtime + emergency redeployment

📅 **Timeline: Plan to address within 30 days**

DETAILED SCAN RESULTS

Each of the seven scanners is documented below with its status, specific findings, business impact, a real-world SME example, and step-by-step remediation guidance.

SSL / TLS Certificate Analysis

⚠️ WARNING

Checks: Certificate validity, expiry date, TLS version (1.2+), cipher strength.

STATUS & FINDINGS

- Certificate expires in 29 days

WHAT THIS MEANS

Your HTTPS certificate is valid but requires attention soon — it may be approaching expiry or using an older configuration. Visitors can still connect securely for now.

WHAT COULD HAPPEN IF NOT FIXED

Your certificate is approaching expiry — visitors will soon see security warnings.

- Browsers display a 'Not Secure' warning when the certificate expires, driving visitors away immediately
- Google may lower your search ranking in response to certificate issues
- Payment and login data could become unencrypted if expiry is not addressed
- GDPR requires adequate technical security — an expired certificate is a violation under Article 32

Responsible:

Your web host or web developer.

REAL-WORLD EXAMPLE — SIMILAR BUSINESS

Business:

SaaS platform, 100 active users, 2023

What happened:

SSL certificate expired over a weekend. Auto-renewal had silently failed months earlier.

Result:

Site inaccessible for 8 hours on a Monday morning. Customers unable to log in.

Cost / Fine:

£3,000 in lost revenue + emergency developer call-out

Lesson:

Certificate monitoring and auto-renewal are critical — expiry is always preventable.

HOW TO FIX THIS

1. Log in to your hosting control panel and locate certificate management

2. Check the expiry date and enable auto-renewal if available

3. Use Let's Encrypt via your host (cPanel, Plesk, Cloudflare all support free auto-renewing certificates)

4. Verify TLS 1.2 and 1.3 are enabled and TLS 1.0/1.1 are disabled in your server config

5. Test your result at <https://www.ssllabs.com/ssltest/>

Time:

30 minutes

Cost:

Free (Let's Encrypt) to £100/year (paid cert)

Who:

Web host or web developer

Urgency:

Within 30 days

HTTP Security Headers

❌ FAIL

Checks: CSP, HSTS, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy.

STATUS & FINDINGS

- Missing header: Content-Security-Policy (critical)
- Missing header: Strict-Transport-Security (HSTS) (critical)
- Missing header: X-Frame-Options
- Missing header: X-Content-Type-Options
- Missing header: Referrer-Policy

WHAT THIS MEANS

Critical security headers are absent. Visitors' browsers have no guidance to protect against common attacks — leaving your site exposed to script injection, clickjacking, and unencrypted connections.

WHAT COULD HAPPEN IF NOT FIXED

No browser security protections — customer data and your reputation are at risk.

- Attackers can inject malicious scripts (XSS) to steal credit card numbers and personal data
- Your site can be embedded in a hidden iframe to trick users into submitting credentials (clickjacking)
- Google Safe Browsing may blacklist your domain — you disappear from search results
- Customers whose data is stolen can sue under GDPR for failing to implement basic security measures
- GDPR fine: up to £17.5 million for inadequate technical security
- Recovering from a hacked site typically costs £1,000–£10,000+

Responsible: Your web host or web designer.

REAL-WORLD EXAMPLE — SIMILAR BUSINESS

Business: E-commerce site, ~50,000 registered customers, 2022
What happened: Missing CSP and HSTS. Attacker injected a payment skimmer script into checkout pages.
Result: 400 customers' credit card details stolen. Mandatory ICO breach report filed.
Cost / Fine: **£15,000 remediation + £8,000 legal fees + ongoing ICO investigation**
Lesson: *CSP and HSTS together prevent the most common client-side attacks. Both are free to add.*

HOW TO FIX THIS

1. Treat this as urgent — contact your web host or developer today
2. Priority headers to add first: Content-Security-Policy and Strict-Transport-Security (HSTS)
3. Then add: X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy
4. Each header is a single configuration line — no application code changes needed
5. Verify at <https://securityheaders.com> until you achieve an A rating

Time: 30–60 minutes **Cost:** Free — server configuration only

Who: Web host or developer with server access **Urgency:** **Immediately — within 7 days maximum**

DNS Records — Email Authentication

✗ FAIL

Checks: SPF, DKIM, and DMARC TXT records for email spoofing prevention.

STATUS & FINDINGS

- No SPF record found
- No DKIM record found (checked common selectors)
- No DMARC record found

WHAT THIS MEANS

Email authentication is not configured. There is nothing preventing an attacker from sending emails that appear to come from your business.

WHAT COULD HAPPEN IF NOT FIXED

Anyone can send emails pretending to be your business — this is an active fraud risk.

- Attackers send phishing emails to your customers appearing to come from your domain
- Customers report fraud, raise chargebacks, and leave negative reviews about your 'scam emails'
- Your domain gets permanently blacklisted by email providers
- Your legitimate invoices and quotes land in spam — you lose real business
- Legal liability if a customer is defrauded using your domain identity
- Average cost of an email fraud incident for an SME: £3,000–£30,000

Responsible: Your DNS/domain provider or IT administrator.

REAL-WORLD EXAMPLE — SIMILAR BUSINESS

Business: Accounting firm, 5 staff, 2023
What happened: No SPF, DKIM, or DMARC. Criminals spoofed the domain to send fake invoices to 12 clients.
Result: Clients paid fraudulent invoices totalling £50,000. Several clients pursued the firm legally.
Cost / Fine: **£8,000 in legal settlements + significant reputation damage**
Lesson: *Without email authentication, your domain can be impersonated by anyone.*

HOW TO FIX THIS

1. Log in to your DNS management console
2. Add SPF: v=spf1 include:_spf.[youremailprovider].com ~all
3. Contact your email provider (Google Workspace, Microsoft 365) for your DKIM public key
4. Add DMARC: v=DMARC1; p=quarantine; rua=mailto:admin@yourdomain.com
5. Verify all three at <https://mxtoolbox.com>
6. After confirming legitimate mail flows correctly, upgrade DMARC to p=reject

Time: 30–45 minutes **Cost:** Free **Who:** Domain registrar admin or IT administrator

Urgency: **Immediately — attackers may be spoofing your domain now**

Open Port Scan

Checks: Ports 80, 443, 22 (SSH), 3306 (MySQL), 5432 (PostgreSQL), 8080, 3000, 27017 (MongoDB).

✓
PASS

STATUS & FINDINGS

✓ No issues found for this check.

WHAT THIS MEANS

Only expected ports are accessible from the internet. Databases and admin services are properly isolated.

Subdomain Enumeration

? ERROR

Checks: Public certificate transparency logs (crt.sh) — passive, no active probing.

STATUS & FINDINGS

Error: Request failed with status code 404

✓ No issues found for this check.

WHAT THIS MEANS

Subdomain lookup via certificate transparency logs failed. This is usually a temporary crt.sh outage — try again later.

Technology Detection

⚠
WARNING

Checks: CMS, frameworks, server software, and version disclosures in headers and source.

STATUS & FINDINGS

- WordPress detected — ensure plugins are up to date

WHAT THIS MEANS

Server or software version information is being disclosed in HTTP headers or page source. This acts as a roadmap for automated attack tools.

WHAT COULD HAPPEN IF NOT FIXED

Technology disclosures give attackers a detailed roadmap of your system.

- Knowing your exact server or CMS version lets attackers search for known exploits immediately
- Automated vulnerability scanners target disclosed versions within hours of indexing
- Outdated CMS plugins are the top cause of SME website compromises
- A hacked site costs £1,000–£10,000+ to clean and restore — plus downtime and SEO damage

Responsible: Your web host or web developer.

REAL-WORLD EXAMPLE — SIMILAR BUSINESS

Business:	Restaurant chain, 3 locations, 2024
What happened:	PHP and server version disclosed in response headers. Known CVE targeted within 24 hours.
Result:	Admin panel compromised via known PHP vulnerability. Reservation data exfiltrated.
Cost / Fine:	£3,500 remediation + 6 hours downtime + emergency redeployment
Lesson:	Hiding version information removes your site from automated exploit target lists.

HOW TO FIX THIS

1. Ask your host or developer to suppress server version headers (X-Powered-By, Server)
2. For Nginx: `server_tokens off;` | For Apache: `ServerTokens Prod + ServerSignature Off` | PHP: `expose_php = Off`
3. Update all CMS plugins to their latest versions from the admin dashboard
4. Set up automatic plugin updates for security releases

Time: 30–60 minutes **Cost:** Free **Who:** Web host or web developer **Urgency:** Within 14 days

GDPR Compliance

× FAIL

Checks: Privacy policy, cookie consent banner, tracking scripts, data subject rights.

STATUS & FINDINGS

- No cookie consent mechanism detected
- Tracking without consent banner: Google Analytics
- No data subject rights information detected

WHAT THIS MEANS

Critical GDPR requirements are missing. You are likely in active breach of UK GDPR, which carries serious regulatory and financial consequences.

WHAT COULD HAPPEN IF NOT FIXED

You are actively breaking UK/EU GDPR law — immediate action required.

- ICO fines: up to £17.5 million or 4% of global annual turnover — whichever is higher
- Individuals can sue for compensation under UK GDPR Article 82
- Every tracking script running without consent is an active, ongoing GDPR violation
- ICO can order you to cease all data processing — effectively shutting down your site
- Directors can face personal liability in cases of wilful non-compliance
- 'I didn't know' is not a legal defence — GDPR requires proactive compliance

Responsible: You are the data controller. Legal responsibility cannot be outsourced.

REAL-WORLD EXAMPLE — SIMILAR BUSINESS

Business: Online retailer, 8,000 registered customers, 2024
What happened: No privacy policy, no consent banner, multiple tracking pixels on every page.
Result: ICO formal investigation. Multiple simultaneous violations. Enforcement notice issued.
Cost / Fine: **£18,000 ICO fine + £5,000 legal fees + mandatory compliance audit**
Lesson: *GDPR is a legal requirement. The ICO investigates complaints from a single individual.*

HOW TO FIX THIS

1. Stop all tracking scripts (Analytics, Facebook Pixel, etc.) loading without consent — this is legally required now
2. Implement a consent management platform that blocks tracking until active consent is given
3. Create or commission a GDPR-compliant privacy policy — do not copy from another site
4. Add data subject rights contact details (right to access, erasure, portability)
5. Register with the ICO as a data controller if processing UK resident data (£40–60/year)
6. Consider consulting a Data Protection Officer (DPO) for a compliance review
7. Document everything — consent mechanisms, processing activities, legitimate interests assessments

Time: 4–8 hours initial. 1–2 hours/month ongoing

Cost: £0–200 implementation. ICO registration: £40–60/year. DPO review: £200–500

Who: Web developer + business owner + potentially a legal/DPO advisor

Urgency: **Immediately — you are in active breach of UK GDPR**

RECOMMENDATIONS — ACTION PLAN

Issues ordered by priority. Addresses the question: "What do we fix first, how long will it take, and who does it?"

Priority 1 (Critical) — Fix within 7 days

1. HTTP Security Headers

Estimated effort: 30–60 minutes

Who: Web host or developer with server access

2. DNS Records — Email Authentication

Estimated effort: 30–45 minutes

Who: Domain registrar admin or IT administrator

3. GDPR Compliance

Estimated effort: 4–8 hours initial. 1–2 hours/month ongoing

Who: Web developer + business owner + potentially a legal/DPO advisor

Priority 2 (Advisory) — Fix within 30 days

1. SSL / TLS Certificate Analysis

Estimated effort: 30 minutes

Who: Web host or web developer

2. Technology Detection

Estimated effort: 30–60 minutes

Who: Web host or web developer

Priority 3 — Ongoing best practice

1. Set up SSL certificate monitoring and auto-renewal alerts

2. Schedule a quarterly security re-scan to track improvements

3. Keep all CMS plugins, themes, and frameworks updated monthly

4. Review DNS records every time a service is decommissioned

5. Conduct an annual full security and GDPR compliance review

GDPR & SECURITY COMPLIANCE CHECKLIST

A quick-reference summary of the key compliance requirements assessed in this scan.

✓ HTTPS enabled (SSL/TLS certificate present and active)

✗ SSL certificate valid and not expired or expiring soon

✗ Critical security headers configured (CSP and HSTS)

✗ All recommended security headers configured

✗ Email authentication configured (SPF / DKIM / DMARC)

✓ No dangerous ports exposed to the internet

✓ Privacy policy present and linked on website

✗ Cookie consent mechanism implemented

✗ No tracking scripts running without user consent

✗ Data subject rights information present

3/10 requirements passing (30%)

RISK ASSESSMENT SUMMARY

Issue count by severity level and overall risk classification.

3 Critical issues (failed checks)

2 Warnings (advisory issues)

1 Passed checks

1 Checks with errors (could not complete)

OVERALL RISK LEVEL

CRITICAL

REMEDIATION TIMELINE

A suggested timeline for addressing all identified issues.

IMMEDIATE ACTION REQUIRED (0–7 DAYS)

- ☐ HTTP Security Headers
- ☐ DNS Records — Email Authentication
- ☐ GDPR Compliance

Estimated effort: See detailed results section

SHORT-TERM (8–30 DAYS)

- ☐ SSL / TLS Certificate Analysis
- ☐ Technology Detection

Estimated effort: See detailed results section

ONGOING (RECOMMENDED BEST PRACTICE)

- Set up SSL certificate monitoring and auto-renewal
- Schedule quarterly security audit (use SecureVault or similar tool)
- Monthly: update CMS plugins, themes, and dependencies
- Annually: review and update privacy policy and cookie consent

NEXT STEPS

Recommended actions after reviewing this report.

1. Review this report with your web designer, web host, or IT team
2. Share the priority list — red items must be fixed within 7 days

3. Request a specific timeline and written confirmation for each fix
4. Implement fixes starting with Critical (red) items first
5. Schedule a follow-up scan in 30 days to verify all fixes are in place
6. Set up SSL certificate monitoring to prevent unexpected expiry
7. Contact SecureVault if you need help interpreting or acting on any findings

Disclaimer: This report was generated by SecureVault automated scanning tools and is provided for informational purposes only. It does not constitute legal advice and does not guarantee GDPR compliance or freedom from regulatory action. Results reflect the publicly observable state of the website at the time of scan and may not capture all security vulnerabilities or compliance issues. Some findings may require professional interpretation. Always consult a qualified security professional or legal advisor for comprehensive compliance guidance. Rescan recommended every 90 days for active monitoring.

Generated: 31 May 2026 | Report ID: SV-MPTRXXXQ | Valid for 30 days from scan date.